基于虚拟化环境的内网资产发现与服务器安全加固

1.搭建隔离实验环境

安装

Oracle VirtualBox

下载

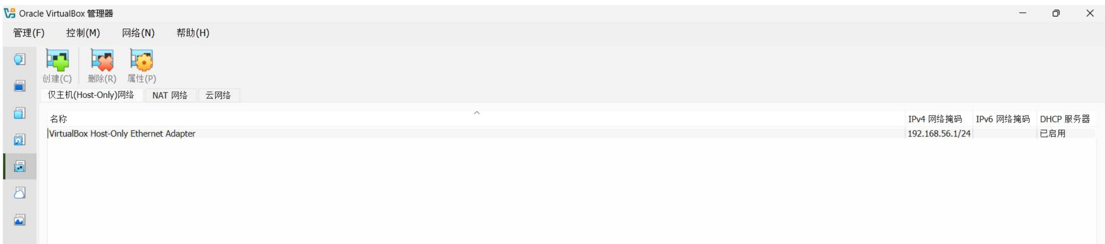
kali-linux-2026.2-installer-amd64.iso

ubuntu-22.04.5-live-server-amd65.iso

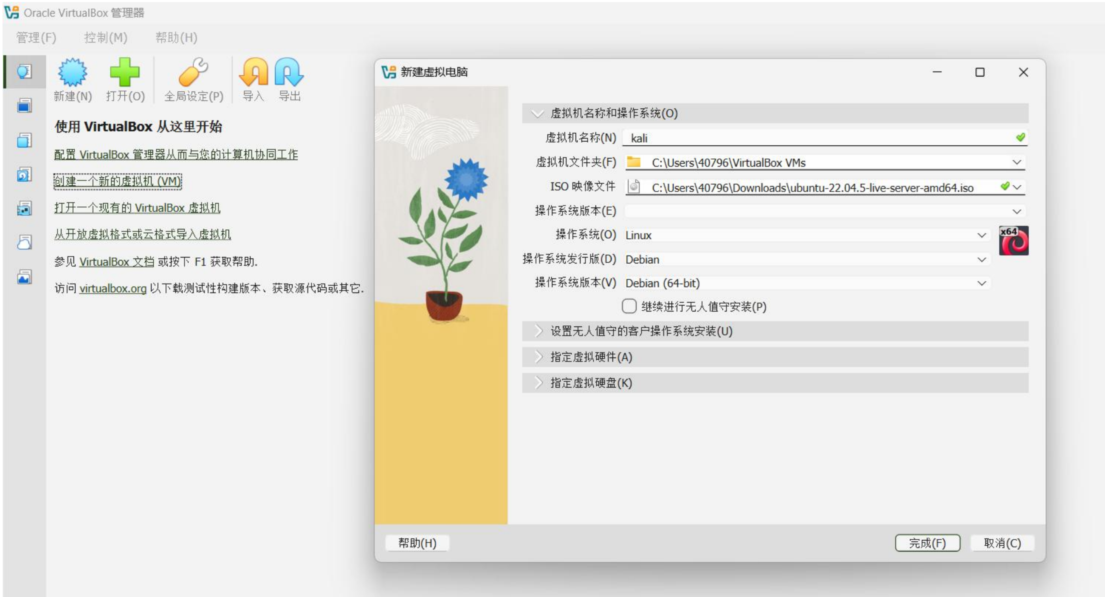
2. 网络规划

此实验不涉及外网，故使用 Host-only 模式

创建隔离内网（DHCP 可启用可不启用）

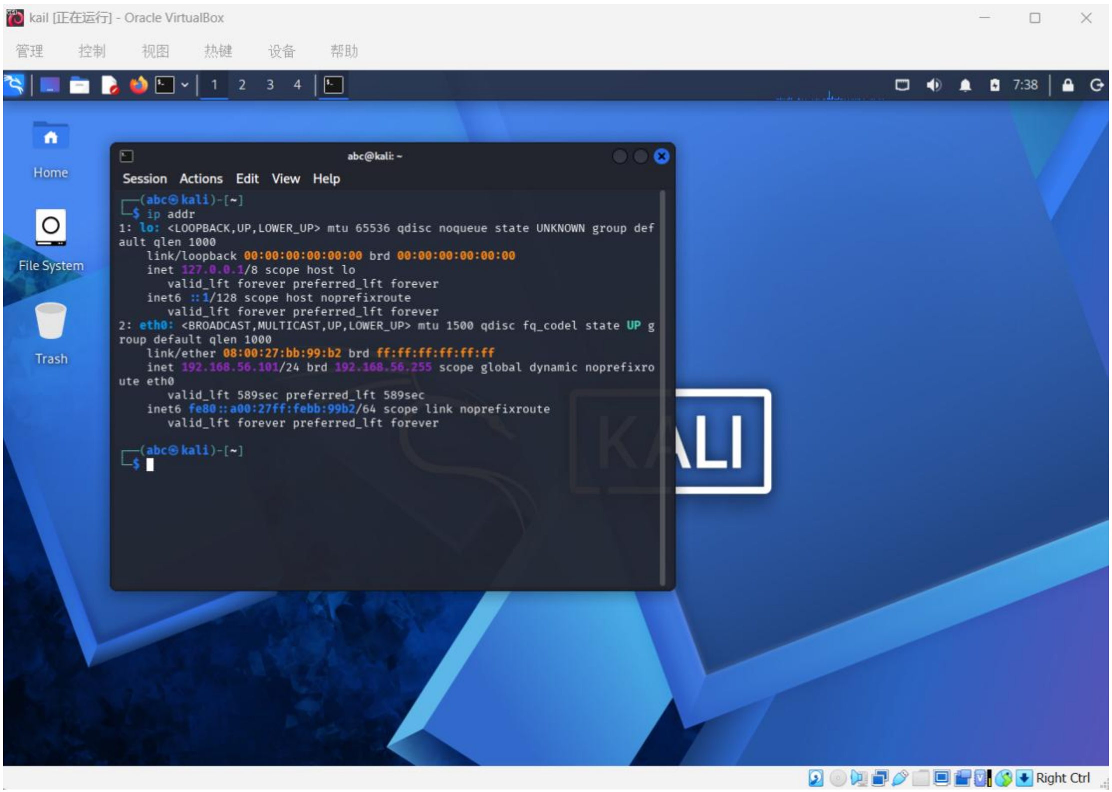


创建 kali 和 ubuntu 两台虚拟机，内存皆设定为 2048KB，cpu 为 2cpu，虚拟硬盘 20GB，硬盘文件类型和格式选择 VDI



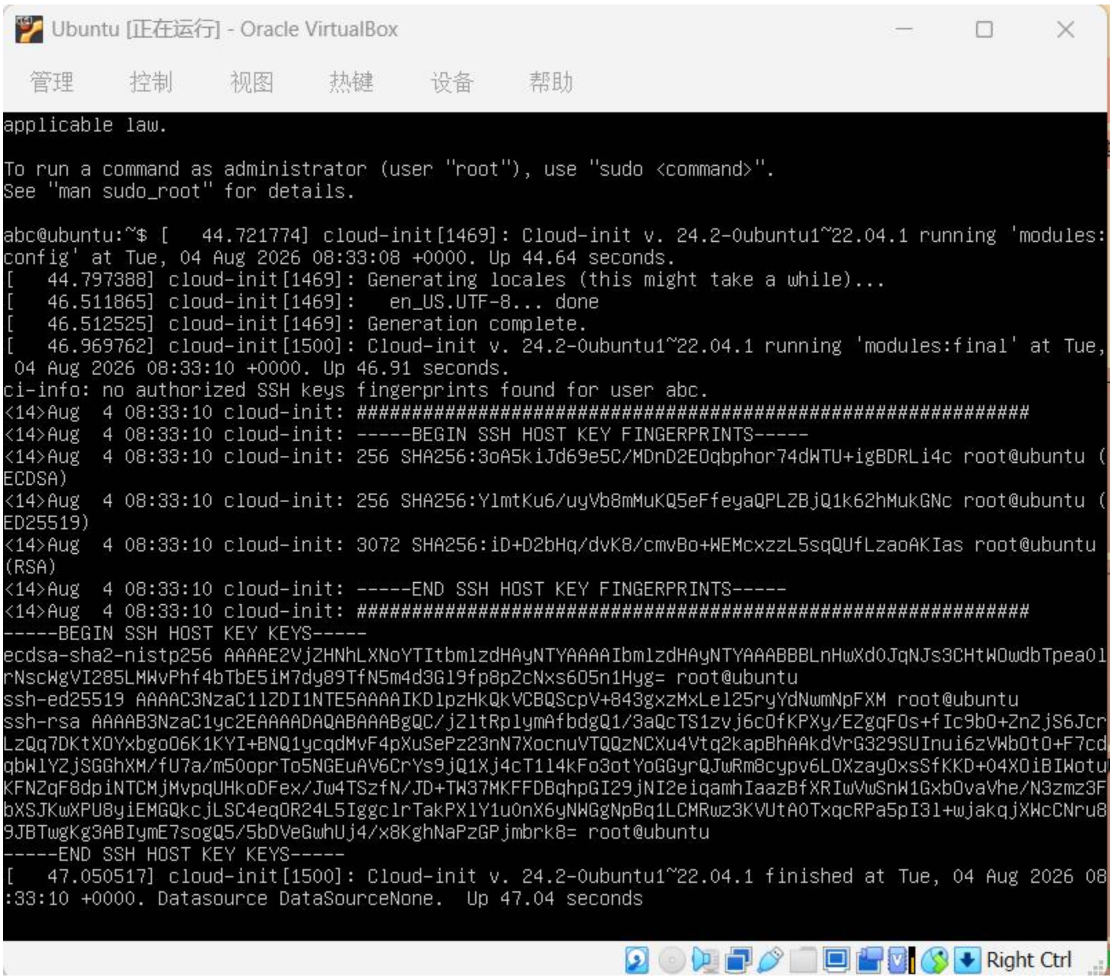
Kali 使用图形界面启动，安装过程中需选择合适的语言、区域等，域名留空，磁盘分区选择适合新手的“使用整个磁盘”

安装完成后打开终端输入 ip addr 验证 ip



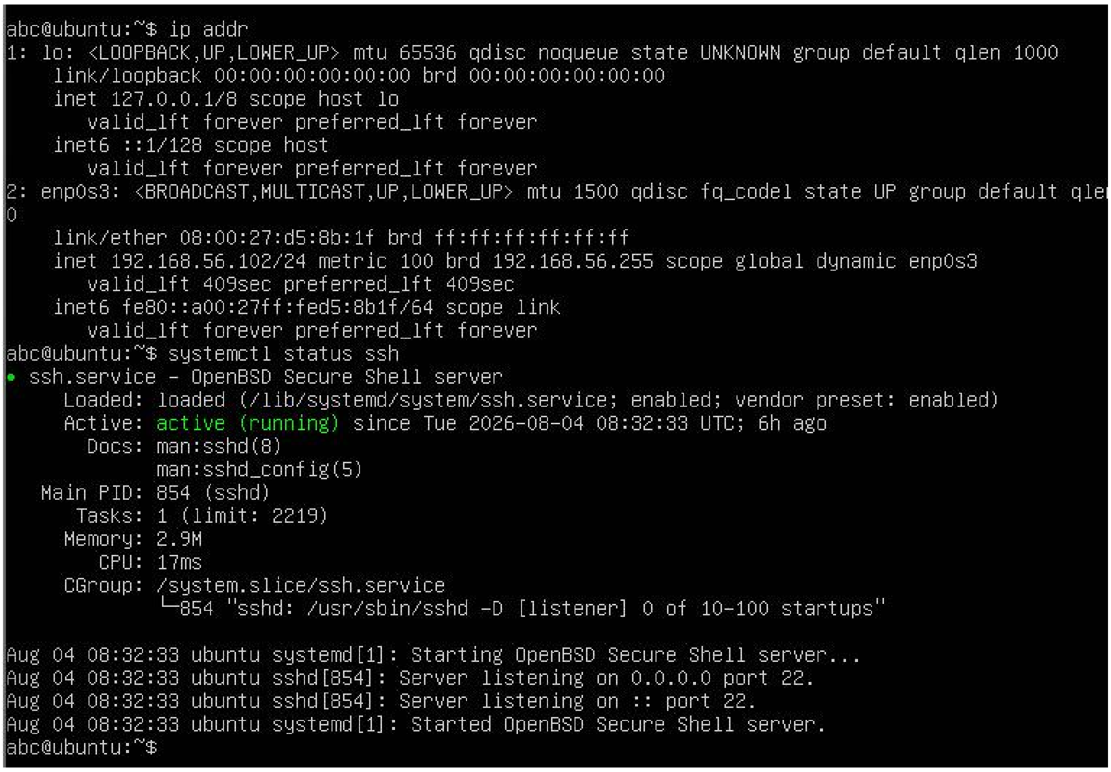
安装 Ubuntu 时需勾选 SSH server，操作较简单，不再赘述。

首次登录成功，后台程序自动打印出的日志：



3. 配置靶机服务

查看 ip（192.168.56.102/24）和检查 ssh



```
abc@ubuntu:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qle
0
    link/ether 08:00:27:d5:8b:1f brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.102/24 metric 100 brd 192.168.56.255 scope global dynamic enp0s3
       valid_lft 409sec preferred_lft 409sec
    inet6 fe80::a00:27ff:fed5:8b1f/64 scope link
       valid_lft forever preferred_lft forever
abc@ubuntu:~$ systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
     Active: active (running) since Tue 2026-08-04 08:32:33 UTC; 6h ago
       Docs: man:sshd(8)
             man:sshd_config(5)
   Main PID: 854 (sshd)
      Tasks: 1 (limit: 2219)
     Memory: 2.9M
        CPU: 17ms
     CGroup: /system.slice/ssh.service
             └─854 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Aug 04 08:32:33 ubuntu systemd[1]: Starting OpenBSD Secure Shell server...
Aug 04 08:32:33 ubuntu sshd[854]: Server listening on 0.0.0.0 port 22.
Aug 04 08:32:33 ubuntu sshd[854]: Server listening on :: port 22.
Aug 04 08:32:33 ubuntu systemd[1]: Started OpenBSD Secure Shell server.
abc@ubuntu:~$
```

之后暂时把 Ubuntu 的网卡切换成 NAT 模式，刷新后在终端依次更新软件源：

sudo apt update

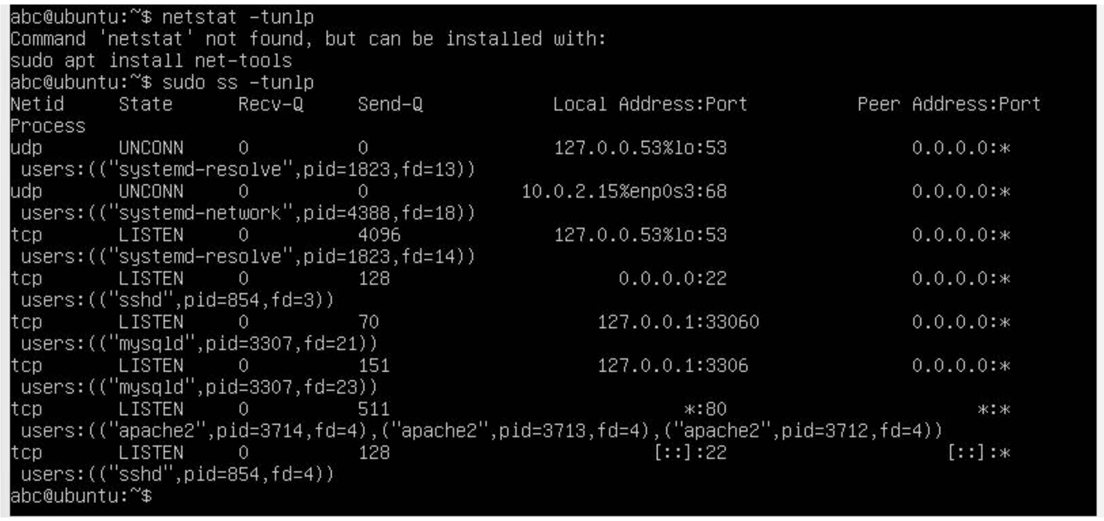
一键安装 Apache Web 和 MySQL 数据库：

sudo apt install -y apache2 mysql-server

启动 Apache 服务：

sudo systemctl start apache2

全部完成后，查看端口完成情况（注：netstat -tunlp 是传统命令，需要预装，否则并不能正常使用，可以用 sudo ss -tunlp 进行端口信息的查看）



```
abc@ubuntu:~$ netstat -tunlp
Command 'netstat' not found, but can be installed with:
sudo apt install net-tools
abc@ubuntu:~$ sudo ss -tunlp
Netid     State      Recv-Q     Send-Q           Local Address:Port          Peer Address:Port
Process
udp       UNCONN     0          0                127.0.0.53%lo:53                0.0.0.0:*
 users:(("systemd-resolve",pid=1823,fd=13))
udp       UNCONN     0          0             10.0.2.15%enp0s3:68                0.0.0.0:*
 users:(("systemd-network",pid=4388,fd=18))
tcp       LISTEN     0          4096             127.0.0.53%lo:53                0.0.0.0:*
 users:(("systemd-resolve",pid=1823,fd=14))
tcp       LISTEN     0          128                    0.0.0.0:22                0.0.0.0:*
 users:(("sshd",pid=854,fd=3))
tcp       LISTEN     0          70                 127.0.0.1:33060               0.0.0.0:*
 users:(("mysqld",pid=3307,fd=21))
tcp       LISTEN     0          151                127.0.0.1:3306                0.0.0.0:*
 users:(("mysqld",pid=3307,fd=23))
tcp       LISTEN     0          511                        *:80                      *:*
 users:(("apache2",pid=3714,fd=4),("apache2",pid=3713,fd=4),("apache2",pid=3712,fd=4))
tcp       LISTEN     0          128                     [::]:22                   [::]:*
 users:(("sshd",pid=854,fd=4))
abc@ubuntu:~$
```

由图可知，22 号端口（SSH 服务，允许任何网络接口连接起来），80 号端口（Web 网站服务，由 apache 发送网页），3306 号端口（MySQL 数据库，让其他程序可以通过网络连接操作此数据库）皆正常工作（注：Ubuntu 22.04 系统在安装 MySQL 时，出于安全考虑，默认已经把 bind-address 设为 127.0.0.1，仅限本机访问）

4.资产发现与安全扫描

Ubuntu 的网卡切换为 Host-only 模式

切回 Kali 虚拟机，打开终端，准备用攻击机做扫描

nmap 的作用就是扫描整个网络发现端口，检查有无漏洞。端口开得越多，潜在的攻击者能溜进来的通道就越多。

在 Kali 的终端中输入:

namp -sn 192.168.56.0/24

```
┌──(abc㉿kali)-[~]
└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 01:42 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.1
Host is up (0.00017s latency).
MAC Address: 0A:00:27:00:00:04 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00021s latency).
MAC Address: 08:00:27:10:6E:11 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up (0.00018s latency).
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.32 seconds
```

接着做基础扫描（只扫描最常用的 1000 个端口）：

nmap 192.168.56.102

```
┌──(abc㉿kali)-[~]
└─$ nmap 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 01:45 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00013s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds
```

再进行全端口扫描（强制扫描从 1 到 65535 的全部端口）：

nmap -p- 192.168.56.102

```
┌──(abc㉿kali)-[~]
└─$ nmap -p- 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 01:46 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00011s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.96 seconds
```

扫描 Ubuntu 上开启的服务和版本（拿到版本号后，就可以去漏洞数据库搜索此版本的已经漏洞加以利用进行攻击）：

nmap -sV 192.168.56.102

```
┌──(abc㉿kali)-[~]
└─$ nmap -sV 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 01:50 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00010s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol
 2.0)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.47 seconds
```

进行操作系统识别（探测靶机是否是 Linux）：

sudo nmap -O 192.168.56.102（-O 使用的是大写英文字母 o，不是数字 0）

```
┌──(abc㉿kali)-[~]
└─$ sudo nmap -O 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 01:57 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00025s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrot
ik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7
.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.o
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.54 seconds
```

漏洞探测脚本（用 Nmap 自动脚本探测风险）：

nmap --script vuln 192.168.56.102

```
┌──(abc㉿kali)-[~]
└─$ nmap --script vuln 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 01:59 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Stats: 0:00:21 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.51% done; ETC: 02:00 (0:00:00 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.000075s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 22.12 seconds
```

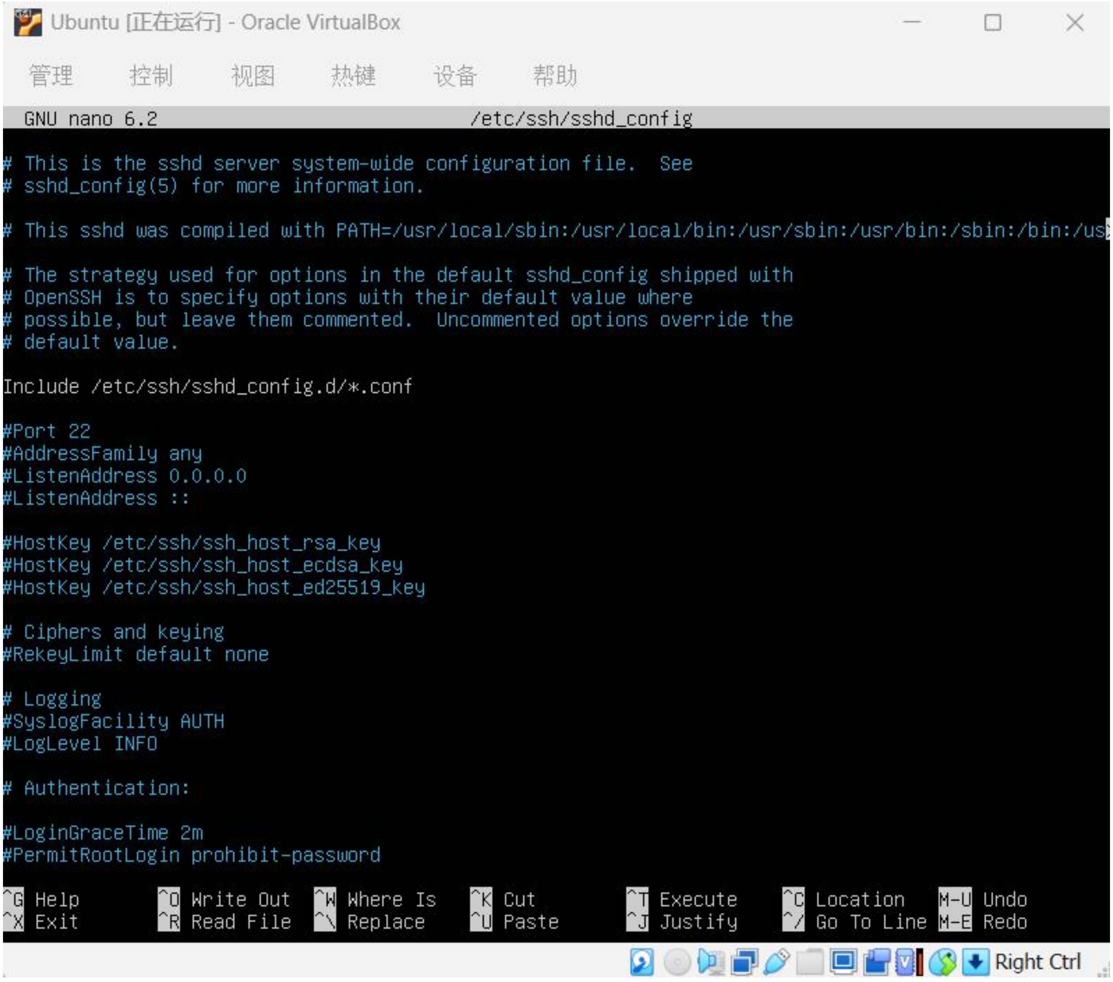
5. 安全加固

切回 Ubuntu 虚拟机

加固 SSH 服务（改端口，禁 root 登录）

打开 SSH 配置文件：

sudo nano /etc/ssh/sshd_config



直接修改即可：

Port 2222

PermitRootLogin no

```
  GNU nano 6.2                                  /etc/ssh/sshd_config *
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/us>

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented.  Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*.conf

Port 2222
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6

^G Help          ^O Write Out     ^W Where Is      ^K Cut           ^T Execute       ^C Location      M-U Undo
^X Exit          ^R Read File     ^\ Replace       ^U Paste         ^J Justify       ^/ Go To Line    M-E Redo
```

（Ctrl+x 保存退出编辑）

重启 SSH 服务让配置生效：

sudo systemctl restart ssh

```
abc@ubuntu:~$ sudo systemctl restart ssh
abc@ubuntu:~$ sudo ss -tunlp
Netid    State     Recv-Q    Send-Q              Local Address:Port            Peer Address:Port
Process
udp      UNCONN    0         0                   127.0.0.53%lo:53                   0.0.0.0:*
 users:(("systemd-resolve",pid=641,fd=13))
udp      UNCONN    0         0            192.168.56.102%enp0s3:68                  0.0.0.0:*
 users:(("systemd-network",pid=639,fd=15))
tcp      LISTEN    0         4096                127.0.0.53%lo:53                   0.0.0.0:*
 users:(("systemd-resolve",pid=641,fd=14))
tcp      LISTEN    0         128                       0.0.0.0:2222                 0.0.0.0:*
 users:(("sshd",pid=1182,fd=3))
tcp      LISTEN    0         151                     127.0.0.1:3306                 0.0.0.0:*
 users:(("mysqld",pid=878,fd=23))
tcp      LISTEN    0         70                      127.0.0.1:33060                0.0.0.0:*
 users:(("mysqld",pid=878,fd=21))
tcp      LISTEN    0         511                             *:80                         *:*
 users:(("apache2",pid=753,fd=4),("apache2",pid=752,fd=4),("apache2",pid=751,fd=4))
tcp      LISTEN    0         128                          [::]:2222                    [::]:*
 users:(("sshd",pid=1182,fd=4))
abc@ubuntu:~$
```

配置 UFW 防火墙策略，只开放必要服务：

sudo ufw allow 2222/tcp

sudo ufw deny 80/tcp

sudo ufw enable

sudo ufw status

```
abc@ubuntu:~$ sudo ufw allow 2222/tcp
Rules updated
Rules updated (v6)
abc@ubuntu:~$ sudo ufw deny 80/tcp
Rules updated
Rules updated (v6)
abc@ubuntu:~$ sudo ufw enable
Firewall is active and enabled on system startup
abc@ubuntu:~$ sudo ufw status
Status: active

To                         Action      From
--                         ------      ----
2222/tcp                   ALLOW       Anywhere
80/tcp                     DENY        Anywhere
2222/tcp (v6)              ALLOW       Anywhere (v6)
80/tcp (v6)                DENY        Anywhere (v6)
```

隐藏 Apache 服务版本

进入 Apache 安全配置文件：

sudo nano /etc/apache2/conf-enabled/security.conf

```
  GNU nano 6.2                    /etc/apache2/conf-enabled/security.conf
# Debian packages.
#
#<Directory />
#   AllowOverride None
#   Require all denied
#</Directory>


# Changing the following options will not really affect the security of the
# server, but might make attacks slightly more difficult in some cases.

#
# ServerTokens
# This directive configures what you return as the Server HTTP response
# Header. The default is 'Full' which sends information about the OS-Type
# and compiled in modules.
# Set to one of:  Full | OS | Minimal | Minor | Major | Prod
# where Full conveys the most information, and Prod the least.
#ServerTokens Minimal
ServerTokens OS
#ServerTokens Full

#
# Optionally add a line containing the server version and virtual host
# name to server-generated pages (internal error documents, FTP directory
# listings, mod_status and mod_info output etc., but not CGI generated
# documents or custom error documents).
# Set to "EMail" to also include a mailto: link to the ServerAdmin.
# Set to one of:  On | Off | EMail
#ServerSignature Off
ServerSignature On

#
^G Help        ^O Write Out   ^W Where Is    ^K Cut         ^T Execute     ^C Location    M-U Undo
^X Exit        ^R Read File   ^\ Replace     ^U Paste       ^J Justify     ^/ Go To Line  M-E Redo
```

修改：

ServerTokens Prod

ServerSignature Off

```
  GNU nano 6.2                  /etc/apache2/conf-enabled/security.conf *
# Debian packages.
#
#<Directory />
#   AllowOverride None
#   Require all denied
#</Directory>


# Changing the following options will not really affect the security of the
# server, but might make attacks slightly more difficult in some cases.

#
# ServerTokens
# This directive configures what you return as the Server HTTP response
# Header. The default is 'Full' which sends information about the OS-Type
# and compiled in modules.
# Set to one of:  Full | OS | Minimal | Minor | Major | Prod
# where Full conveys the most information, and Prod the least.
#ServerTokens Minimal
ServerTokens Prod
#ServerTokens Full

#
# Optionally add a line containing the server version and virtual host
# name to server-generated pages (internal error documents, FTP directory
# listings, mod_status and mod_info output etc., but not CGI generated
# documents or custom error documents).
# Set to "EMail" to also include a mailto: link to the ServerAdmin.
# Set to one of:  On | Off | EMail
#ServerSignature Off
ServerSignature Off

#

^G Help       ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo
^X Exit       ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^/ Go To Line M-E Redo
```

保存退出后重启 Apache:

sudo systemctl restart apache2

6. 二次扫描

在 kali 终端中进行端口扫描

```
┌──(abc㉿kali)-[~]
└─$ nmap -p- 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 03:13 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 0.72% done
Stats: 0:01:45 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Sc
an
SYN Stealth Scan Timing: About 7.16% done; ETC: 03:37 (0:22:42 remaining)
```

```
┌──(abc㉿kali)-[~]
└─$ nmap -p 22,80,2222,3306 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 03:26 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00025s latency).

PORT     STATE    SERVICE
22/tcp   filtered ssh
80/tcp   filtered http
2222/tcp open     EtherNetIP-1
3306/tcp filtered mysql
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.62 seconds
```

切换回 Ubuntu 中修改防火墙规则，开放 80 端口：

sudo ufw allow 80/tcp

```
abc@ubuntu:~$ sudo ufw allow 80/tcp
[sudo] password for abc:
Rule updated
Rule updated (v6)
abc@ubuntu:~$ sudo ufw enable
Firewall is active and enabled on system startup
abc@ubuntu:~$
```

在 kali 进行版本检测扫描：

nmap -sV -p 80,2222 192.168.56.102

```
┌──(abc㉿kali)-[~]
└─$ nmap -sV -p 80,2222 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 05:57 +0000
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.102
Host is up (0.00027s latency).

PORT     STATE SERVICE VERSION
80/tcp   open  http    Apache httpd
2222/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protoc
ol 2.0)
MAC Address: 08:00:27:D5:8B:1F (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.38 seconds
```